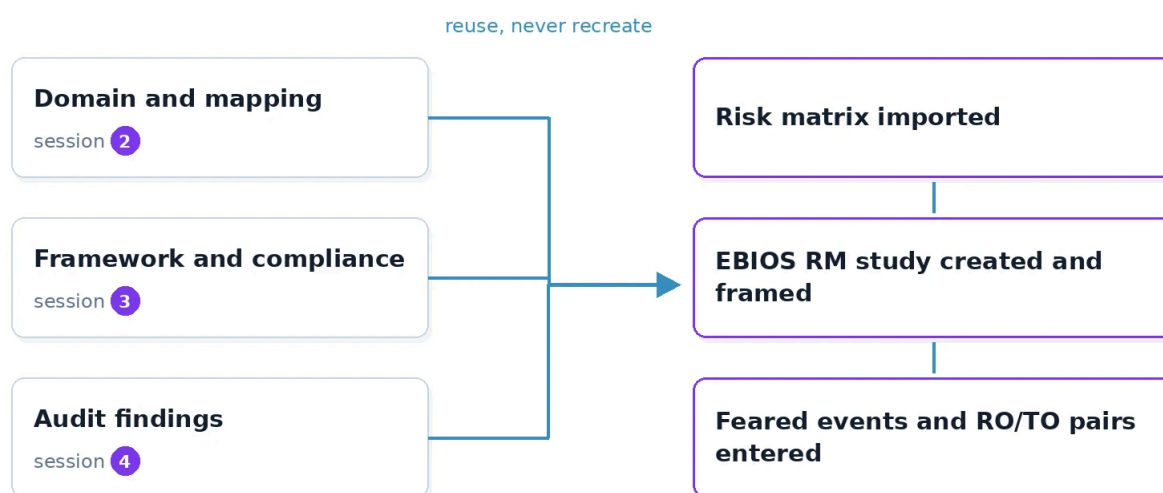


Entering Workshops 1 and 2 into CISO Assistant

✓ **Goal:** by the end of the hour, the working group's instance carries the study



Session objectives

What this lab teaches:

- **Check** that the objects created in CISO Assistant during the previous sessions are indeed the foundation of the risk study, and reuse them without recreating them
- **Import** a risk matrix from the tool's library and explain why the study cannot exist without it
- **Create** the MERIDIAN group's EBIOS RM (expression of needs and identification of security objectives, the ANSSI (the French national cybersecurity agency) method) study in the tool's EBIOS RM module, attached to

the right domain, framed, linked to the assets and to the baseline

- **Enter** the feared events rated for severity, then the risk origin / target objective pairs evaluated and selected, as the tutorial produced them
- **Justify** why workshops 3, 4 and 5 stay empty today, and what the tool says about it

Prerequisites

- This afternoon's tutorial: the study framing, the six rated feared events, the baseline table and the five evaluated RO/TO (risk origin / target objective) pairs, three of them retained. This lab enters what the tutorial produced: without the tutorial's copy, there is nothing to enter.
- The CISO Assistant instance of the subsidiary under review, with what the previous sessions built: the subsidiary's domain and the mapping entered in session 2, the framework imported in session 3, the session 4 audit.

The principle of the lab

A risk study that lives in an office document dies at the first update. The group's GRC (governance, risk and compliance) tool is built to carry the study over time: the method's review cycles assume that, a year from now, the same objects are found in the same place, linked to the same assets. This lab therefore transposes the results of workshops 1 and 2 into the EBIOS RM module of CISO Assistant, and it applies a rule inherited from the whole course: reuse, never recreate. Every object entered since session 2 will be used; recreating a duplicate would be the beginning of the divergence between the tool and reality.

The tool's EBIOS RM module is built on the guide's five workshops: one study, and for each workshop its activities, named as in the guide. Workshop 1 carries four activities, define the study framework, define the business and technical perimeter, identify the feared events, determine the security foundation; workshop 2 carries three, identify the risk origins and targeted objectives, evaluate the RO/TO pairs, select the RO/TO pairs. These are, one by one, the four exercises of the tutorial. Session 6 will fill workshops 3 and 4 of the same study, session 7 workshop 5, whose first activity generates the risk assessment: nothing will be copied over from one session to the next.

A word of honesty about the interface: the labels quoted here are those of the version deployed on the platform, checked on the model instance. If the instance shows a slightly different screen, find the object by its name rather than by its position in the menu, and report the difference in the write-up: that is exactly what a CISO does when the tool evolves.

✓ Exercise 1: the inventory of what already exists (10 minutes)

Before entering anything, prove that the foundation is there. Open the instance and check, noting for each the exact name observed:

1. The subsidiary's domain created in session 2 (MERIDIAN-SANTE, MERIDIAN-LOGISTIQUE, MERIDIAN-EDUCATION or MERIDIAN-TERRITOIRES), the second domain that carries the other end of its cross-subsidiary dependency, and the perimeter associated with the subsidiary under review.
2. The assets entered in session 2: the business assets and supporting assets of the subsidiary under review, including those of its cross-subsidiary dependency from S6 of the subsidiary pack.
3. The framework imported in session 3 and the compliance assessment created with it, the session 4 audit with its statuses filled in.
4. The EBIOS RM module, Risk menu, "EBIOS RM" entry, "EBIOS RM studies" page: the list is empty, as expected.

To produce: a four-line table, expected object, present or absent, exact name observed. If an object is missing, do not recreate it silently; note it, report it, and continue the lab with what exists. A gap in the tool is a piece of governance information, not a personal obstacle.

✓ Exercise 2: importing the risk matrix (10 minutes)

By construction, the tool refuses to create an EBIOS RM study without a risk matrix: rating without a scale means nothing, and the tool is stricter than many organisations on this point. The CISO Assistant library offers several ready-made matrices; the one for this module is called "4x4 risk matrix from EBIOS-RM", described as based on the official guide of the method. Catalog, Libraries, search for "EBIOS", import.

Import it from the library, then open it and really look at it, because it will be the scale for the whole rest of the module:

1. The likelihood axis carries four levels, from V1 "Unlikely" to V4 "Certain".
2. The consequence axis carries four levels, from G1 "Minor" to G4 "Critical". Note in passing the word the tool chose: "Consequence", where the guide and the tutorial say "severity". It is the same concept, and this duplicated vocabulary is an excellent reminder: ISO 27005 speaks of consequences where EBIOS RM speaks of feared events and severity.
3. Crossing the two axes produces three risk levels: Low, Medium, High.

To produce: three sentences. Which cell of the grid corresponds to the highest risk, what colour the diagonal is, and above all: are the labels of this matrix exactly those of the guide's example scale seen in the tutorial? Look closely at levels V4 and G3 before answering.

Exercise 3: creating the study and setting ✓ the framework, workshop 1, activities 1, 2 and 4 (15 minutes)

Risk menu, "EBIOS RM" entry, then the add button, the icon at the top right of the list. Name, according to the module's convention: "Étude EBIOS RM MERIDIAN - [subsidiary under review] et [dependency from §6] - cycle 1", where [subsidiary under review] is the name of the subsidiary whose pack the group holds and [dependency from §6] the short title of its main cross-subsidiary dependency, read in §6 of the subsidiary pack, for instance "Santé et approvisionnement d'urgence" or "Territoires et annuaire commun du pôle". Domain: the subsidiary's, never the root domain. Risk matrix: the one imported in exercise 2, the gesture that ties the study to a scale. Quotation method: choose "Manual", because session 7 will enter the likelihood of each operational scenario by hand; with "Express", the tool would recompute it from the operating modes and overwrite the entry. Once the study is created, its page shows the five workshops and their activities; the three of this lab are in workshop 1.

1. **Frame**, activity 1 "Define the study framework": fill in the study's description with the tutorial's framing, the study's objective in one sentence, the participants and their roles, the durations of the two cycles, and the person responsible for accepting residual risks. A reader who opens the study in six months must find the framework there without looking for the tutorial's copy.
2. **Link**, activity 2 "Define business and technical perimeter": on the activity 2 page, the select-an-asset button opens the list of existing assets; tick there the business assets and supporting assets of the subsidiary under review entered in session 2, cross-subsidiary dependency included. Leave the neighbouring add-an-asset button alone, it would create a new one: create nothing, rename nothing, link.
3. **Anchor**, activity 4 "Determine the security foundation": attach to the study the session 4 audit, the subsidiary's compliance assessment. The tool derives the baseline and its gaps from it; the tutorial's baseline table remains the written reference, and its retained gaps become input data of the study.

To produce: the study created, visible in the domain's list of studies, with its framework in the description, its assets linked and its audit attached; the "Summary" card of the study page shows the Assets and Audits counters.

Exercise 4: entering the six feared events, workshop 1, activity 3 (20 minutes)

From the study page, workshop 1, activity 3 "Identify feared events", then the list's add button, one per tutorial line. The form carries the fields ID, Name, Description, Gravity, Justification, Assets, Qualifications and the "Selected" box.

1. **Name** the feared event with the tutorial's wording, the one that names the business asset affected and the security need hit; fill in the ID, ER1 to ER6, to find the tutorial's lines again.
2. **Link** the asset: the business asset concerned, entered in session 2. The tool reminds it under the field, a feared event attaches to business assets, not to supporting assets.
3. **Qualify** the security need hit, among the tool's qualifications: Availability, Integrity, Confidentiality, and "Proof" for traceability, as the tool does not use that word.
4. **Rate** the severity on the matrix's scale: Minor, Significant, Important, Critical. Correspondence with the tutorial's scale, to note on the worksheet: minor = Minor, significant = Significant, serious = Important, critical = Critical.
5. **Justify** the rating in the Justification field, with the tutorial's justification, and tick "Selected".

To produce: six feared events in the activity 3 list, each with its asset, its qualification, its severity and its justification; the "Feared events" counter of the summary shows 6.

Exercise 5: entering the RO/TO pairs, workshop 2 (25 minutes)

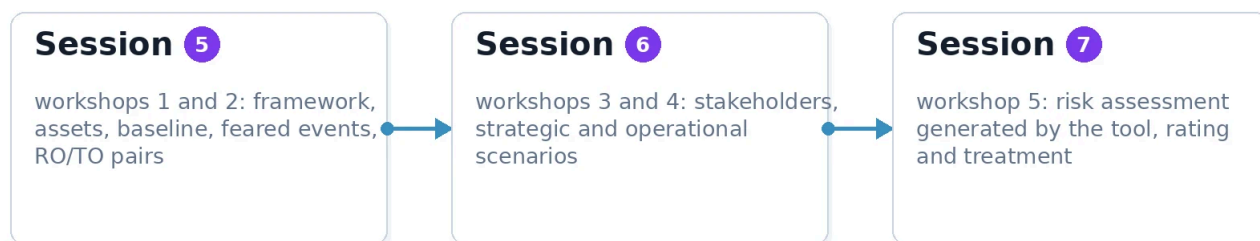
From the study page, workshop 2, activity 1 "Identify risk origins and targeted objectives", then the list's add button, one per candidate pair of the tutorial, five in all. The form is split according to the three activities of the workshop, and that is exactly the order of exercise 4 of the tutorial.

1. **Identify**, activity 1: the risk origin, among the tool's categories, State, Organized crime, Terrorist, Activist, Competitor, Amateur, Avenger, Pathological, Other; then the targeted objective, stated as a purpose, in the tutorial's words. The cybercriminal is entered as "Organized crime"; the malicious employee or provider as "Avenger", the guide's category for the insider.
2. **Evaluate**, activity 2: motivation (Very low, Low, Significant, Strong), resources (Limited, Significant, Important, Unlimited) and activity level (Very low, Low, Moderate, Important), then the justification of the activity by its observable element in the Justification field. Correspondence with the tutorial's three positions: low = Low or Limited, medium = Significant or Moderate, high = Strong, Important.

3. **Select**, activity 3: tick "Selected" on the three pairs selected in the tutorial and leave the other two unticked; link each pair, selected or not, to the feared events it targets, according to the tutorial's correspondence table.
4. **Read** the Pertinence column of the list: the tool computes it on its own by crossing motivation and resources, on four levels, from "Irrelevant" to "Highly relevant". It may differ by one step from the tutorial's pertinence, because activity does not enter its calculation: note the difference on the worksheet, do not change the selection to please it, the written justification prevails.

To produce: five pairs in the workshop 2 list, three selected, each linked to at least one feared event; the "RO/TO pairs" counter of the summary shows 5.

What is NOT done today, and why: workshops 3, 4 and 5 stay empty. The method still requires it: the strategic scenarios and the ecosystem are the subject of session 6, the operational scenarios and their likelihood too, and workshop 5 is that of session 7, where the first activity, "Generate the risk assessment", will create the register from the study. A workshop that is empty because the method is not there yet is a normal state; a workshop filled with improvised objects is worse than an empty one, because it looks finished.



Answer keys and validation criteria – cliquer pour révéler